

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 4:	Pentest em Aplicações Web
Atividade 2:	Vulnerabilidades no Processo de Autorização e Controle de Acesso
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Pentest em Aplicações Web*, para a qual utilizamos a sala do PortSwigger - <https://portswigger.net/>

No contexto desta sala, nosso foco é:

- 1) Através do robots.txt descobrir um diretório que será acessado através do browser para termos acesso de administrador e excluir o usuário carlos;
- 2) Conseguir através de uma mensagem antiga do chat a senha do usuário carlos para entrar diretamente na conta dele;
- 3) Ter acesso de administrador através de requisição get para manipular o controle de acesso e dar privilégios administrativos para um usuário que não deveria ter esta permissão; 4) Utilizar algumas etapas para transformar o usuário wiener em administrador, através do cookie de autorização de outro usuário que é administrador.

A sala do Portswigger é composta por quatro tarefas:

- 1) Funcionalidade de administrador desprotegida - <https://portswigger.net/web-security/access-control/lab-unprotected-admin-functionality>
- 2) Referência direta a objetos inseguros- <https://portswigger.net/web-security/access-control/lab-insecure-direct-object-references>
- 3) O controle de acesso baseado em método pode ser contornado - <https://portswigger.net/web-security/access-control/lab-method-based-access-control-can-be-circumvented>
- 4) Processo multipassos sem controle de acesso em uma etapa - <https://portswigger.net/web-security/access-control/lab-multi-step-process-with-no-access-control-on-one-step>

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

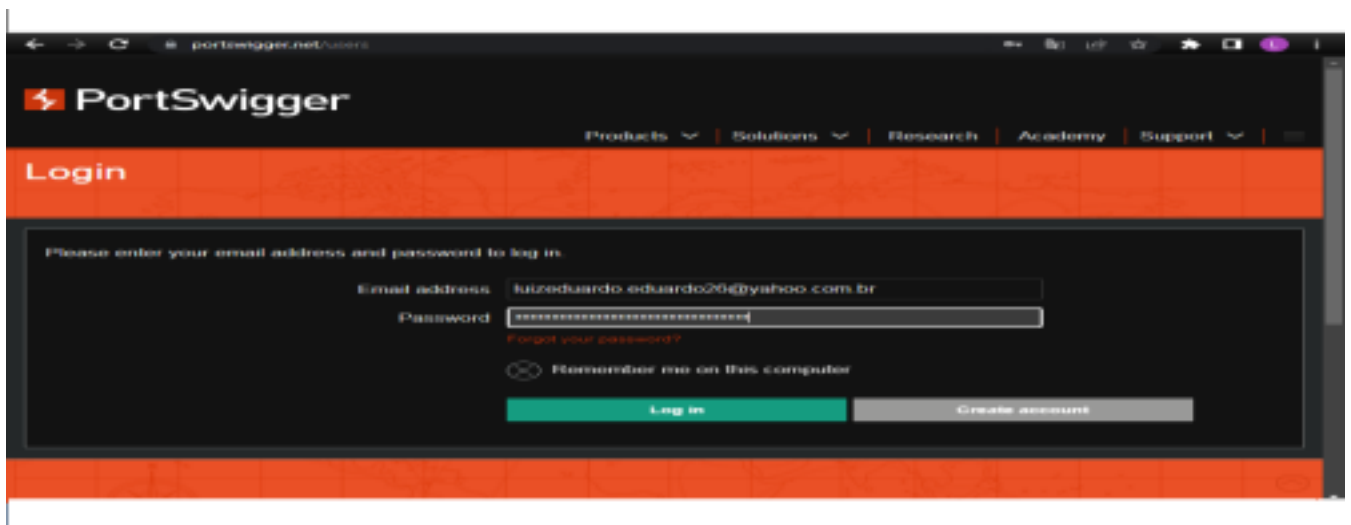
- 1) Acessar os sites informados acima.
- 2) Utilizar a VM do Kali Linux: Para utilizar o Burp e executar alguns comandos no terminal.

2.2. Atividade prática

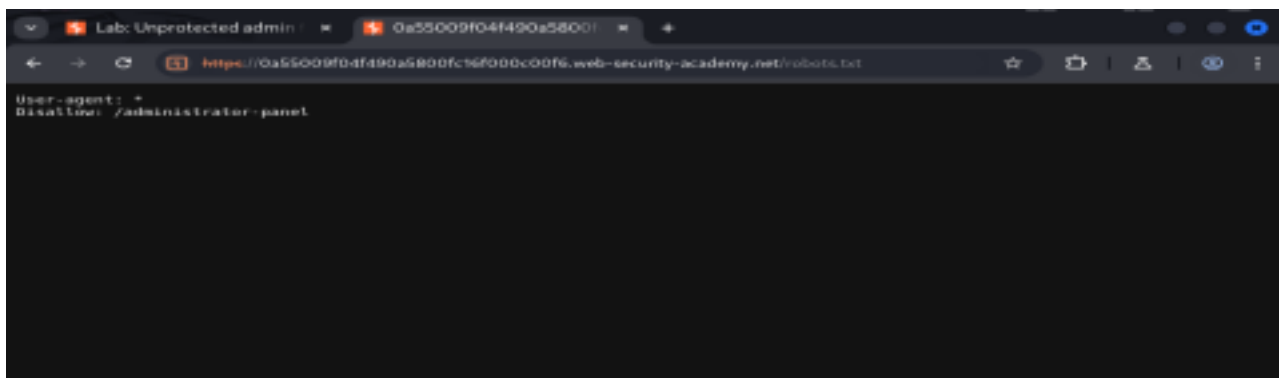
O objetivo desta atividade é realizar as 4 tarefas propostas no PortSwigger

2.3. Atividade 1 - Funcionalidade de administrador desprotegida.

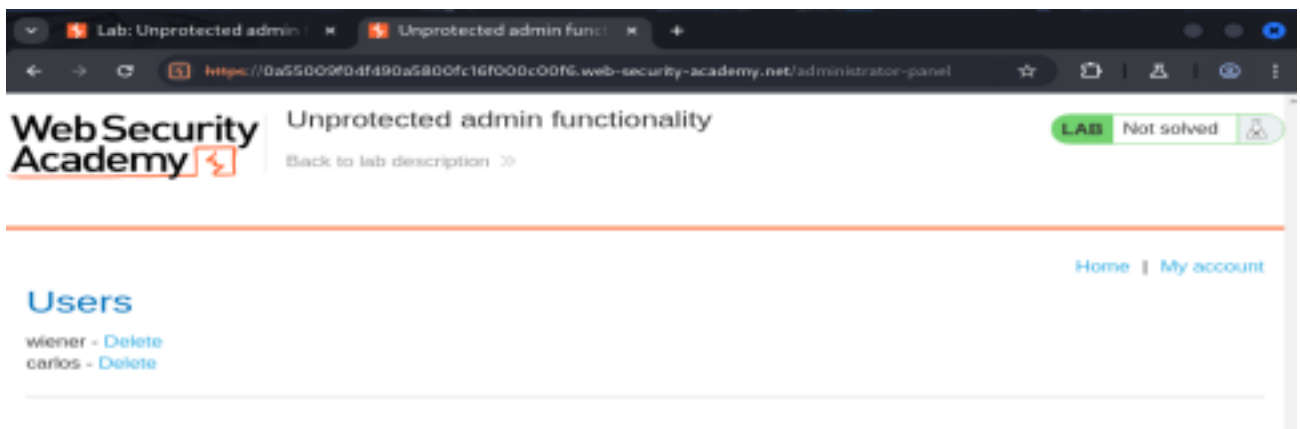
Passo 1 – Entre com seu login e senha no PortSwigger no site: <https://portswigger.net/web-security/access-control/lab-unprotected-admin-functionality> e clique em acesse o laboratório.



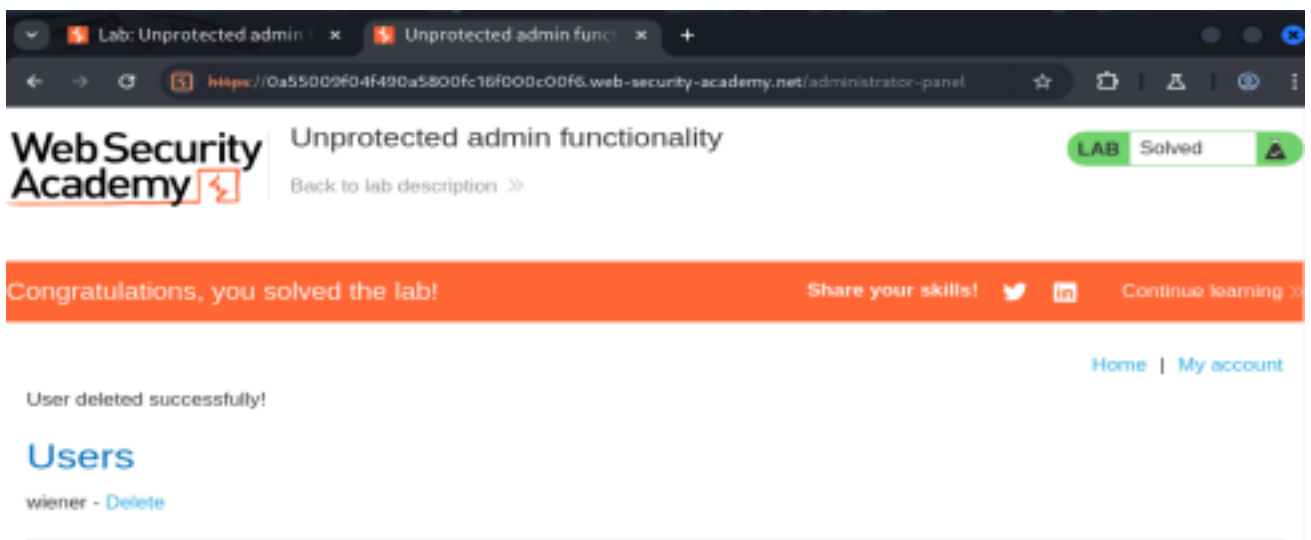
Passo 2 – Vai aparecer o site: <https://0a55009f04f490a5800fc16f000c00f6.web-security-academy.net> e para ver as páginas não indexadas coloque /robots.txt após o academy.net



Passo 3 – Conforme mostrado na imagem acima substituir o /robots.txt por /administrator-panel e excluir o usuário carlos.



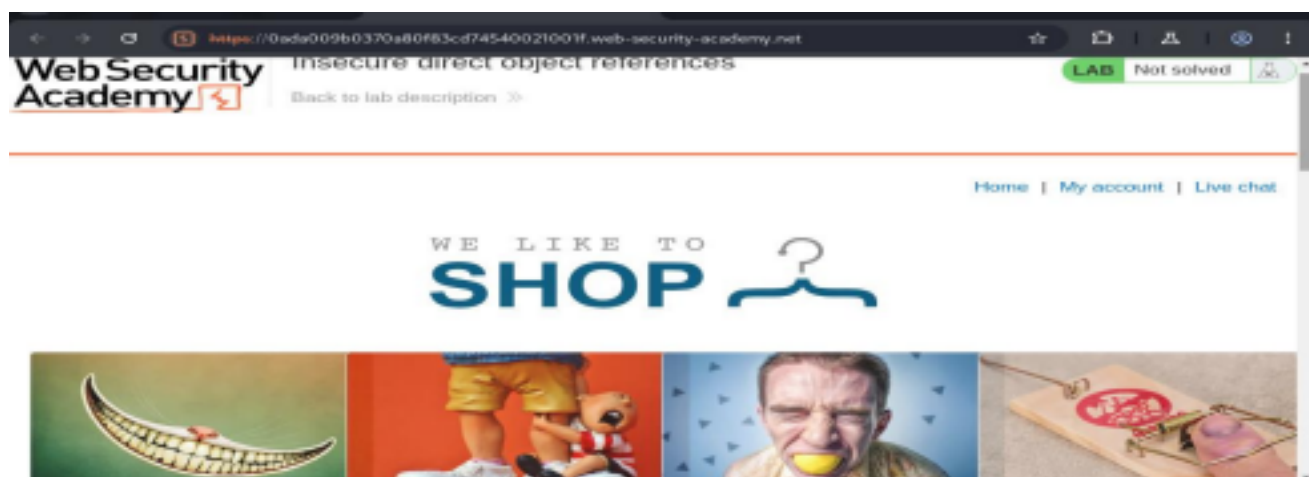
Passo 4 – O laboratório está concluído.



3

2.4. Atividade 2 – Referência direta a objetos inseguros.

Passo 1 – Aparecerá o site <https://0ada009bo370a80f8cd74540021001f.web-security-academy.net>



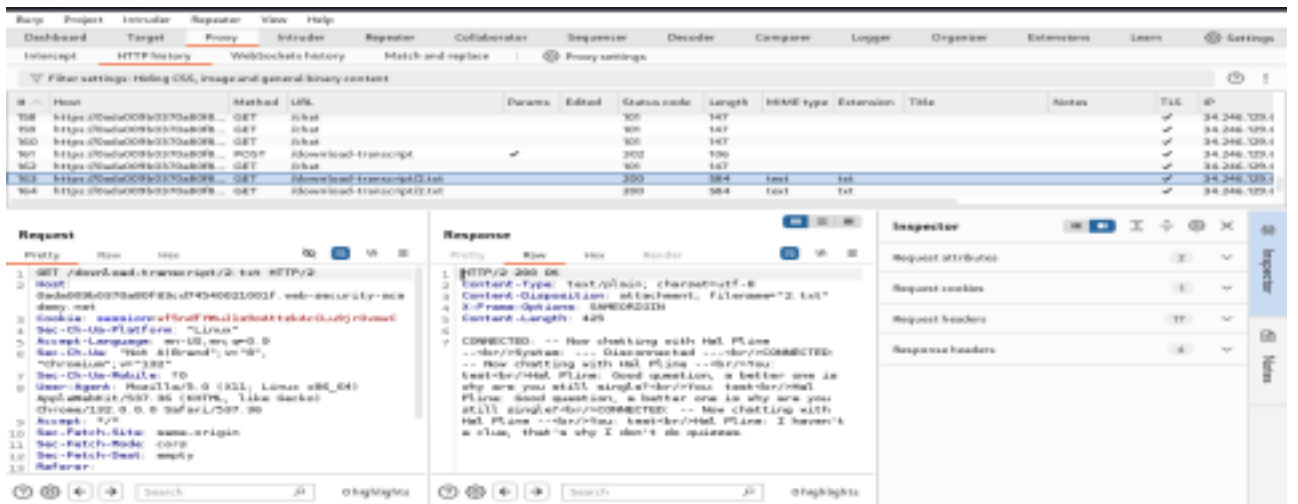
Passo 2 – Depois clique em Live chat e digite test e depois clique em Send.



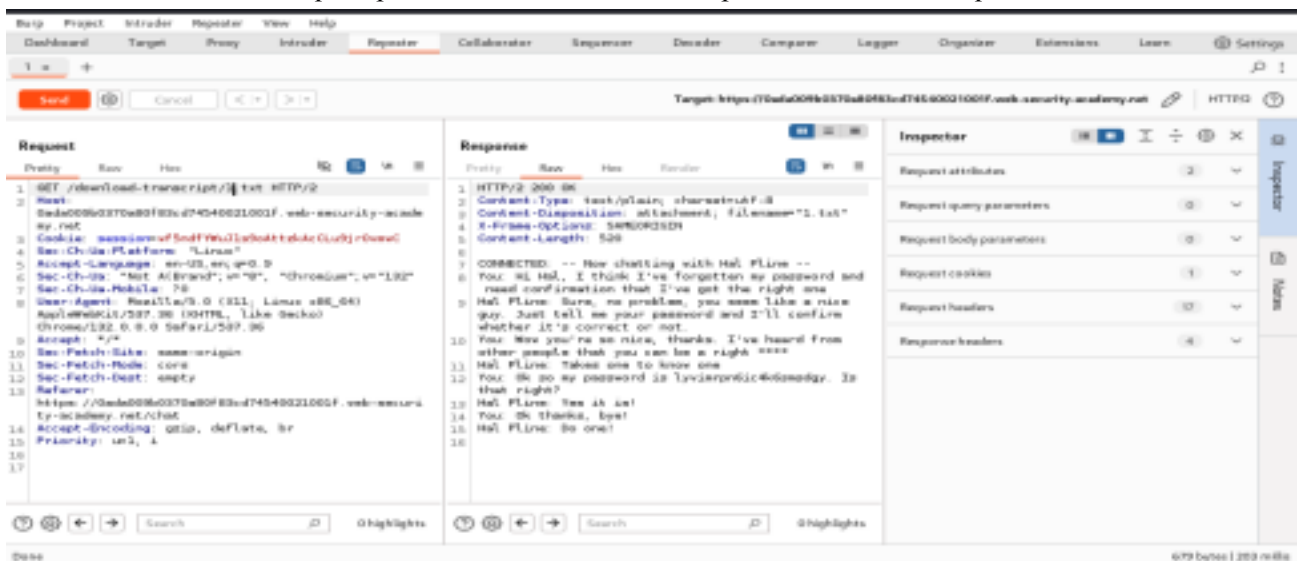
Passo 3 – Fique repetindo a palavra test, depois clique em view transcript para baixar para o seu computador a conversa



Passo 4 – Abra o Burp Suite encontre a URL /download/transcript/2.txt e envie para o Repeater.

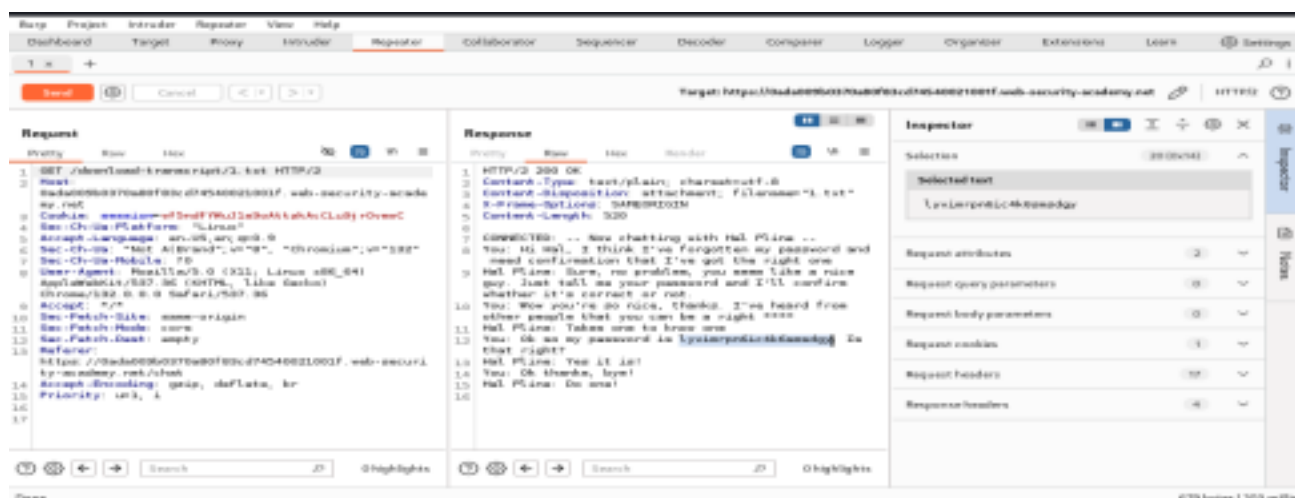


Passo 5 – Substitua no Request para GET /download-transcript/1.txt HTTP/2 e clique em Send

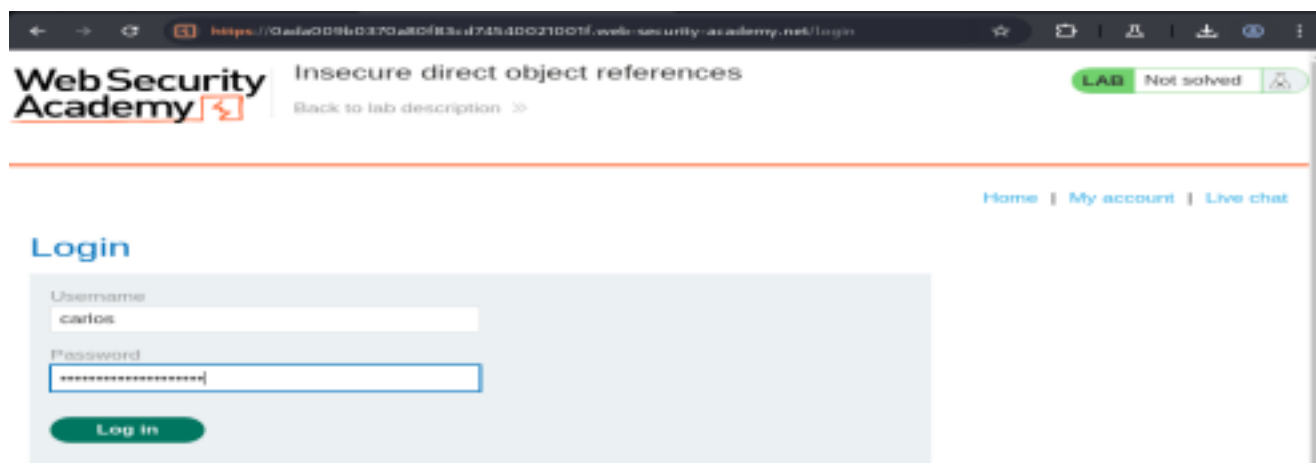


5

Passo 6 – No texto informado no response copie a senha informada neste chat.



Passo 7 – Clique em My Account e digite no usuário carlos e na senha cole o que copiou do chat.



Passo 8 – O laboratório está concluído.



6

2.5. Atividade 3 – O controle de acesso baseado em método pode ser contornado.

Passo 1 – Acesse o site, clique em My account e digite no usuário administrator e na senha admin e clique em login

Web Security Academy Method-based access control can be circumvented LAB Not solved 

[Back to lab description >>](#)

[Home](#) | [My account](#)

Login

Username

Password

[Log in](#)

Passo 2 – Va até Admin Panel, selecione o usuário carlos (NORMAL) e clique em Upgrade user.

Web Security Academy Method-based access control can be circumvented LAB Not solved 

[Back to lab description >>](#)

[Home](#) | [Admin panel](#) | [My account](#)

User



[Upgrade user](#) [Downgrade user](#)

Passo 3 – Agora o usuário carlos tem acesso de administrador.

Web Security Academy Method-based access control can be circumvented LAB Not solved 

[Back to lab description >>](#)

[Home](#) | [Admin panel](#) | [My account](#)

User



[Upgrade user](#) [Downgrade user](#)

7

Passo 4 – Vá até o Burp Suite em Proxy /HTTP History e ache a URL /admin-roles.



Passo 5 – Agora retorne até a página do browser em My account e clique em Log out.



Passo 6 – Agora entre com o usuário wiener em my account digite o usuário wiener e a senha peter



8

Passo 7 – Volte ao Burp em Proxy HTTP History procure por /my-account?id=wiener em Request copie o cookie da sessão e clique em Send to Repeater.



Passo 8 – No Repeater clique em Send e aparecerá no Response o código 401 Não autorizado.



Passo 9 – Agora modifique no Repeater para a requisição para GET /admin-roles?username=wiener&action=upgrade HTTP/2, foi encontrado o código 302 - Found



Passo 10 – Agora o usuário wiener tem acesso de administrador e o laboratório está concluído.



2.6. Atividade 4 – Processo multipassos sem controle de acesso em uma etapa.

Passo 1 – Acesse o site, clique em My account e digite no usuário administrator e na senha admin e clique em login.



Passo 2 – Vá até o Admin Panel e faça upgrade no usuário carlos



Passo 3 – No Burp clique em Proxy/HTTP History, encontre a URL /admin-roles e vá em Response e clique com o botão direito do mouse e send to Repeater.



Passo 4 – Aparecerá uma tela de confirmação se tem certeza que deseja alterar a permissão do carlos para administrador clique em Yes.



Passo 5 – Volte para o Burp clique em Proxy/HTTP History , encontre a outra URL /admin-roles e vá em Response e clique com o botão direito do mouse e send to Repeater.



Passo 6 – No browser vá até My account e clique em logout e logar com o usuário wiener e senha peter.



Passo 7 – Agora no Burp vá até o Repeater e na aba 1 no final de Request troque o username de carlos

para wiener.



Passo 8 – Faça o mesmo procedimento na aba 2 e troque o username de carlos para wiener.



Passo 9 – Na aba 1 clique em Send e aparecerá que não foi autorizado código 401 – Não - Autorizado.



Passo 10 – Na aba 2 clique em Send e aparecerá que foi encontrado código 302 - Encontrado



Passo 11 – O laboratório foi concluído com sucesso.



Interpretação dos resultados:

- 1) Na Atividade 1 - Funcionalidade de administrador desprotegida: verificar no arquivo robots.txt indexadores que não irão aparecer na página do google e dentro do browser colocar o /administrator-panel para ter acesso de administrador e excluir o usuário carlos.
- 2) Na Atividade 2 - Referência direta a objetos inseguros: Interação com o chat, depois baixar a conversa 2.txt e manipular no Repeater para que ele nos mostre outra conversa do chat 1.txt onde terá a senha do usuário carlos e poderemos entrar em sua conta através desta senha.
- 3) Na Atividade 3 - O controle de acesso baseado em método pode ser contornado: entramos como administrador do sistema para colocar o usuário carlos como administrador, fazemos logout e entramos com o usuário wiener que é um usuário comum não tendo acesso de administrador e através de uma manipulação de requisição de POST para GET teremos acesso de administrador para o usuário wiener sem precisar ter acessado a aplicação com o usuário administrator.
- 4) Na Atividade 4 - Processo multipassos sem controle de acesso em uma etapa: Vamos novamente entrar com o login e senha do administrador e colocar o usuário carlos como administrador, desta vez vamos utilizar o cookie que foi encontrado no Burp quando tornamos o carlos administrador e utilizar para que o usuário wiener seja administrador e consiga ter este acesso mesmo não tendo permissão.

2.8. Mitigação:

- 1) No laboratório 1: Tomar cuidado com o arquivo robots.txt para que os arquivos que não sejam indexados não sejam também acessados via browser de forma direta;
- 2) No laboratório 2: Temos uma interação com o chat, depois podemos até baixar esta conversa, não utilizar números sequenciais por exemplo 1.txt, 2.txt pois poderá ser interceptada uma conversa que o usuário não tem autorização de ver;
- 3) No laboratório 3: Precisamos ficar atentos à manipulação de requisição, para que não possa trocar um post por get por exemplo e ter acesso de administrador do sistema;
- 4) No laboratório 4: Podemos utilizar a requisição para tornar o carlos administrador e mudando alguns campos tornar o usuário comum wiener em administrador sem ter este acesso, temos que ter o controle de sessão, o controle de cookies para que isso não aconteça.

3. Considerações finais

Nesta sala, exploramos técnicas Pentest em Aplicações Web com o software Burp Suite Community para manipular algumas requisições, utilizando o Repeater para enviar requisições automaticamente,

para conseguir ter acesso ao Admin Panel do site mesmo logando com um usuário comum e fazer a exclusão de um funcionário

As principais lições aprendidas incluem:

- 1) Não deixar caminhos que possam ser explorados via browser pois estes caminhos podem ser usados para conseguir acesso privilegiado
- 2) Os arquivos de chat não podem ser sequenciais ou de fácil adivinhação pois, pode haver uma manipulação e um usuário pode ver conversas de outros usuários as quais ele não tem autorização, pode conseguir acesso a dados pessoais ou confidenciais.
- 3) Verificar possíveis manipulações de requisição e controle de cookies para não ser possível a escalção de privilégios.

Foi verificado que é bem fácil alterar os parâmetros no browser, o Burp também é bem fácil de utilizar e tem recursos que deixam a manipulação do site ainda mais fácil como o Repeater e o Proxy HTTP para capturar as informações e depois manipulá-las de forma a conseguir escalção de privilégios ou acesso a dados confidenciais.

4. Referências

Site: <https://portswigger.net/web-security/access-control/lab-unprotected-admin-functionality>

Site: <https://portswigger.net/web-security/access-control/lab-insecure-direct-object-references>

Site: <https://portswigger.net/web-security/access-control/lab-method-based-access-control-can-be-circumvented>

Site: <https://portswigger.net/web-security/access-control/lab-multi-step-process-with-no-access-control-on-one-step>